

# Attack Analysis of NTU Campus Access Control Systems

何文璦

National Taiwan University  
Department of Electrical Engineering  
Taipei, Taiwan

彭詳睿

National Taiwan University  
Department of Computer Science and Information  
Engineering  
Taipei, Taiwan

秦驊佑

National Taiwan University  
Department of Computer Science and Information  
Engineering  
Taipei, Taiwan

楊翔宇

National Taiwan University  
Department of Computer Science and Information  
Engineering  
Taipei, Taiwan

## Abstract

Access control systems in campus rely on networked IT/OT pipelines that connect RFID credentials, card readers, door controllers, serial-to-IP converters, and backend management servers. While this architecture improves scalability and centralized administration, it also expands the attack surface across both physical and network layers. In this study, we present an authorized security assessment of the department-level access control infrastructure at National Taiwan University.

Our study identifies four classes of weaknesses in the current system: UID-based authentication that enables card cloning, a Telnet authentication bypass vulnerability in the BF-430 converter, controller communication exposed to ARP-based man-in-the-middle attacks, and weak protection against login attempts on the web management interface. Through these proof-of-concept experiments, we show how these vulnerabilities can compromise the access control pipeline. We further discuss potential directions for mitigating these risks and strengthening the security of the access control infrastructure. Our findings demonstrate that legacy access control deployments can introduce significant security challenges, and underscore the importance of security improvements in NTU campus environments.

## 1 Introduction

Physical access control systems have evolved significantly from standalone mechanical locks to networked, software-driven infrastructures. Modern deployments form a layered *IT/OT pipeline*: a proximity card presents a credential to a reader, which forwards it over a serial bus to a door controller, which in turn communicates with a backend management server over the campus IP network [9]. This convergence of operational technology (OT) and information technology (IT) substantially expands the attack surface: vulnerabilities that were once physically isolated now become remotely exploitable.

Campus environments are a particularly high-value target. A university access control system must simultaneously serve tens of thousands of cardholders, remain available around the clock, and protect sensitive spaces such as research laboratories, server rooms, and administrative offices. Despite these requirements, institutional deployments frequently lag behind security best practices due to budget constraints, long hardware refresh cycles, and

the operational difficulty of updating embedded devices without disrupting physical access [2].

The NTU department-level access control system studied in this work exemplifies these tensions. The pipeline consists of NXP MIFARE Classic 1K contactless cards, PXR-34MSKL card readers, Hundure HAC/RAC door controllers, and CHIYU BF-430 serial-to-TCP/IP converters bridging the RS-485 bus to the campus network. Each component introduces distinct weaknesses: the RFID cards rely on an unauthenticated, plaintext UID for identity; the BF-430 converter carries a critical Telnet authentication bypass (CVE-2021-31251, CVSS 9.8 [11]), transmits serial frames in plaintext over a shared subnet, and exposes a web management interface with no brute-force protection.

Prior work has examined RFID cloning [6], protocol-level weaknesses in Wiegand-based systems [1], and the general taxonomy of access-control reader attacks [9], but end-to-end empirical analysis of a production campus pipeline combining physical-layer, network-layer, and application-layer vulnerabilities is less common. This paper closes that gap with a fully authorized, non-destructive security assessment of the CSIE and EE building access control infrastructure at National Taiwan University.

Our main contributions are:

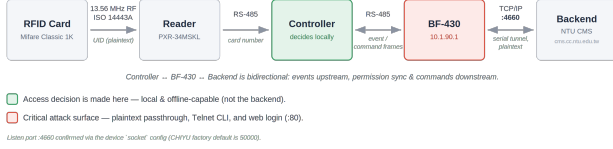
- A complete threat model of NTU access control pipeline, mapping each component to its exploitable weakness.
- Four proof-of-concept attacks demonstrated under school authorization: (1) MIFARE UID cloning using a CUID magic card and RC522/Arduino; (2) unauthenticated Telnet shell access via CVE-2021-31251; (3) ARP cache poisoning enabling man-in-the-middle interception of plaintext controller frames; and (4) dictionary-based credential brute-force against the BF-430 web login.
- Actionable, prioritized remediation recommendations for each vulnerability.

The remainder of this paper is organized as follows. Section 2 defines the system model and threat surface. Section 3 presents each attack with experimental results. Section 4 surveys related work. Section 5 concludes and outlines future work.

## 2 Problem Definition

### 2.1 System Architecture

The NTU department access control system forms a unidirectional-identity, bidirectional-command pipeline spanning five components, illustrated in Figure 1.



**Figure 1: System architecture and data flow of the NTU access control pipeline.**

**RFID Card (Component ①).** NXP MIFARE Classic 1K cards operating at 13.56 MHz under ISO 14443A. Card identity is encoded solely as a 4-byte UID in Sector 0, Block 0. The UID is transmitted in plaintext during the ISO 14443-3 anticollision sequence and requires no sector key to read [8].

**Card Reader (Component ②).** PXR-34MSKL readers function purely as edge sensors: they capture the UID and forward a card number to the controller over RS-485 (or Wiegand). No access decision is made at the reader.

**Door Controller (Component ③).** Hundure HAC/RAC controllers are the sole decision point. Each unit maintains a local cardholder database (~40,000 entries) and event log (~100,000 entries), evaluating card validity, time-window restrictions, and disability status entirely offline. The controller drives the door lock relay and buffers audit events until the backend link is restored.

**Serial-to-IP Converter (Component ④).** A CHIYU BF-430 unit bridges the controller’s RS-485 bus to the campus Ethernet as a transparent TCP tunnel on port 4660. It forwards controller ↔ backend frames unmodified and in plaintext. The device additionally exposes a Telnet CLI and an HTTP web management interface on port 80.

**Backend CMS (Component ⑤).** cms.cc.ntu.edu.tw, operated by the NTU Computing Center, serves as the central management console. It pushes cardholder database updates, permission changes, and time-sync commands downstream, and collects audit events upstream. Due to its campus-wide PII scope, the backend is explicitly out of this study’s authorized scope.

### 2.2 Attack Surface Enumeration

Table 1 summarizes each component’s role, the data it stores, and its primary security weakness.

Four attack surfaces are in scope for this work:

**UID Cloning.** The system performs UID-only authentication, never activating the ISO 14443-4 application layer or verifying any encrypted sector. Because the UID is broadcast without a key and writable to CUID-class “magic” cards, any attacker who comes within NFC read range of a victim card can produce a functionally identical clone [12].

**Telnet Authentication Bypass (CVE-2021-31251).** Firmware versions v1.0.0–v3.23 of the BF-430 contain a state machine flaw

**Table 1: Component overview and key weaknesses**

| Component  | Role               | Key Weakness                                          |
|------------|--------------------|-------------------------------------------------------|
| RFID Card  | Identity token     | UID is plaintext & cloneable                          |
| Reader     | Edge sensor        | Wiegand link tap (physical, out of scope)             |
| Controller | Access decision    | Local DB sync traffic tamperable                      |
| BF-430     | Serial ↔ IP bridge | Plaintext passthrough; CVE-2021-31251; weak web login |
| Backend    | Central mgmt       | PII scope (out of scope)                              |

in the Telnet negotiation handler. Sending three specific IAC (Interpret As Command) sequences transitions the firmware into an anomalous state in which it treats the connection as already authenticated, granting an administrative shell without credentials [7, 11].

**ARP Spoofing / MITM.** The BF-430 is deployed on the departmental subnet with no Dynamic ARP Inspection (DAI) configured on the access switch. An attacker on the same Layer-2 segment can poison the BF-430’s ARP cache, redirecting its upstream TCP stream toward the gateway through an attacker-controlled host, enabling passive inspection or selective manipulation of plaintext controller frames [15].

**Dictionary Attack on Web Login.** The BF-430’s HTTP management interface accepts Basic Authentication with no account lockout or multi-factor requirement. Although a sliding-window rate limit exists, it does not prevent sustained credential guessing, making the interface susceptible to automated dictionary attacks [5].

### 2.3 Security Properties Violated

The four attacks collectively undermine three fundamental security properties. *Authentication* is broken by both UID cloning (the system cannot distinguish a cloned card from the original) and the Telnet bypass (the device grants administrative access without verifying any credential). *Integrity* is threatened by the ARP spoofing MITM position, which allows an adversary to modify or selectively drop controller ↔ backend frames, including permission updates and audit logs. *Confidentiality* is violated by the plaintext serial tunnel, which exposes cardholder event records (card number, door ID, timestamp, grant/deny decision) to any on-path observer.

### 2.4 Threat Model

Each of the four attacks assumes a distinct adversary capability level and entry point. We model them separately to clarify the realistic preconditions for exploitation.

**UID Cloning.** The attacker is an *unprivileged physical proximity adversary* who only needs brief NFC read range ( $\leq 10$  cm) to a victim’s student ID card, such as through a lost card or close contact in a crowded setting. No campus network access, credentials, or sector keys are required. The attack uses only off-the-shelf equipment: an NFC-capable smartphone, a CUID-class writable card, and a low-cost RFID writer.

**Telnet Authentication Bypass (CVE-2021-31251).** The attacker is a *network-local adversary* with Layer-3 reachability to the BF-430’s management address and knowledge of its TCP port (23). No valid account credentials are needed. In the NTU deployment, the BF-430 is reachable from within the campus network, so any user connected to the campus wired network or campus WiFi—or anyone able to connect a device to a walled Ethernet port—satisfies the prerequisite.

**ARP Spoofing / MITM.** The attacker is a *same-subnet adversary*: a host that has been assigned (or has self-assigned) an IP address on the same Layer-2 segment as the BF-430. This is a stronger precondition than the Telnet attack, but remains realistic given that the access-control subnet was not isolated from the general departmental network at the time of our study. No special privileges on the switch are required; standard ARP poisoning tooling (e.g. arpspoof/dsniff or ettercap) suffices [15].

**Dictionary Attack on Web Login.** The attacker is again a *network-local adversary* with HTTP reachability to the BF-430’s web interface (port 80). The attack requires no prior knowledge of valid credentials; it depends solely on the absence of any brute-force countermeasure. Successful login yields the same device management capability as the Telnet bypass, but through the HTTP interface rather than the CLI.

### 3 Results

In this section, we present the results of four attacks against different components of the access control pipeline. For each attack, we first describe the attack rationale, then introduce the experimental setup, and finally report the observed results.

#### 3.1 UID Cloning Attack

**3.1.1 Attack Rationale.** The attack targets RFID Card (Component ①) of the access control pipeline, the NXP MIFARE Classic 1K card. As established in the system architecture, authentication relies solely on the UID stored in plaintext at Sector 0, Block 0, and reading this value requires no other credentials.

**3.1.2 Experimental Setup.** The victim’s card UID is captured using NFC tools [14] on an Android NFC-capable smartphone, which obtains the UID from the ISO 14443-3 anti-collision procedure required no sector key. The captured UID is subsequently written onto a CUID Magic Card (Gen2) using an RC522 reader module connected to an Arduino. Unlike genuine Mifare Classic cards, on which Sector 0, Block 0 is factory-locked and read-only, the magic card permits this block to be rewritten, allowing the UID to be freely modified.

**3.1.3 Results.** In our observation, each step of the attack flow, including scanning the victim card’s UID with NFC Tools, writing it to the magic card, and testing the cloned card at a door reader, could be completed in under 5 seconds. This indicates that the attack requires very little time to execute.

The cloned card was first tested at a CSIE department-building door reader and was accepted on the first attempt, with behavior indistinguishable from that of the original card. To assess whether the issue was limited to a single location, the same cloned card was also tested at the Electrical Engineering building and the Main

Library. According to the NTU General Affairs Office, the CSIE and Electrical Engineering buildings appear to use the same access control system, while the Main Library uses a separate system. The cloned card was accepted at all tested locations, suggesting that the issue is not limited to a single reader or access control system.

This behavior is consistent with the access control units relying only on the card UID for authentication, without validating the card’s encrypted sectors. As a result, the server records entries made with the clone as legitimate swipes of the victim’s card, undermining the reliability of the access logs.

#### 3.2 Telnet Authentication Bypass

**3.2.1 Attack Rationale.** This attack targets the Telnet management interface exposed by the BF-430 serial-to-Ethernet converter (Component ④), which bridges the door controller’s RS-485 bus to the campus IP network. CVE-2021-31251 (CVSS 3.1 base score: 9.8, Critical) describes a flaw in the BF-430’s Telnet negotiation state machine affecting firmware versions v1.0.0 through v3.23.

**3.2.2 Experimental Setup.** First, we connected the attacking machine to the same reachable network segment as the BF-430 device and established a TCP connection to its Telnet service on port 23. After the TCP three-way handshake, the exploit script sent a crafted sequence of Telnet IAC negotiation bytes, including `\xff`, `\xfb`, `\xfd`, `\x01`, `\x03`, and `\x18`. This malformed negotiation sequence forced the device into an invalid state, causing the firmware to prematurely mark the session as authenticated and directly grant access to the built-in BF-430 CLI, as summarized in Figure 2.

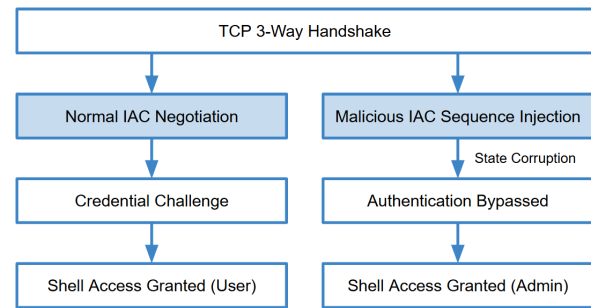


Figure 2: Protocol Negotiation Flowchart.

**3.2.3 Results.** Execution of the exploit script reliably granted a root-level CHIYU shell session without supplying any credentials. Issuing the `help` command within this shell revealed a comprehensive set of privileged administrative operations accessible to an unauthenticated attacker, including modification of the device’s management IP address, modification of its MAC address, execution of a full system reboot, restoration of factory-default configuration, and some more privileged operation shown in Figure 3. These results confirm that the authentication bypass yields complete administrative control over the IT/OT bridge component of the access control pipeline with no observed inconsistency.

```

python exploit.py
[+] 嘗試連線...
[+] 認證成功! 輸入 'help' 查看可用指令

(GH1VU shell) $ help

help
help
[Describe command usage]
system
[System management and display status and statistic information]
serial
[Config serial port [type] [baud rate] [parity] [data bits] [stop bits] [flow control]]
ipconfig
[Config networking connection mode]
socket
[Config socket connection mode]
ping
[Diagnostic command]
forcetime
[Serial force transmit time]
delaytime
[Setups transmission delay time]
pppoe
[PPPoE module control and configure]
ddns
[Dynamic DNS]
manageip
[Change Management IP address]
changemac
[Change MAC address]
hostname
[Change System Hostname]
location
[Change System Location name]
reboot
[reboot system]
NtSave
[save system configuration]
resetdefault
[reload system configuration to factory default]

(GH1VU shell) $ ^C
[+] 中斷連線

```

Figure 3: Root access CLI after authentication bypass attack.

### 3.3 ARP Spoofing / Man-in-the-Middle

**3.3.1 Attack Rationale.** The Address Resolution Protocol (ARP) maps IP addresses to MAC addresses and is cached, unauthenticated, by every host on a subnet so that Layer-2 frames can be delivered to the correct interface [15]. As described in Section 2, the BF-430 maintains a continuous upstream TCP connection to the campus access-control backend; any frame it sends outside its local subnet is first forwarded to its configured default gateway. By broadcasting forged ARP replies that bind the gateway’s IP address to an attacker-controlled MAC address, an attacker on the same Layer-2 segment can cause the BF-430 to deliver all of its upstream traffic to the attacker first, establishing a man-in-the-middle (MITM) position from which the traffic can be passively inspected, selectively dropped, or modified before being forwarded onward.

Although the door-opening decision itself is made locally by the door controller rather than by the BF-430, occupying this MITM position still benefits an attacker. As a concrete example, an attacker who has already obtained unauthorized entry – e.g. via a cloned UID card (Section 2) – could intercept and drop the corresponding audit-event frame before it reaches the backend. The entry would then leave no trace in the centrally monitored access log: the event remains buffered locally on the controller, but in practice such local logs are rarely inspected, since they are expected to be synchronized to the backend automatically.

**3.3.2 Experimental Setup.** We targeted the BF-430 unit serving our department building, chosen for its physical accessibility. With the assistance of teaching assistants in Room 217, we obtained two IP addresses on the same subnet as the target BF-430 unit. Layer-2 reachability to the device was confirmed by pinging its IP address and observing the corresponding entry appear via `arp -a`.

To respect the non-destructive testing principle stated in our Ethical Considerations, we did not poison the ARP cache of the production BF-430 itself. Instead, the two allocated IP addresses were assigned to two machines under our control: Computer A

(Ubuntu), acting as the attacker, and Computer B (Windows), acting as the victim. Because both machines share the same subnet, switch port group, and absence of ARP-spoofing defenses as the BF-430, the feasibility of poisoning Computer B’s ARP cache directly reflects the feasibility of poisoning the BF-430’s.

**3.3.3 Results.** On Computer A, we ran:

```
sudo arpspoof -i eth0 -t <B_IP> <gateway_IP>
```

which continuously sent forged ARP replies telling Computer B that the gateway’s IP address resolved to Computer A’s MAC address. We then recorded Computer B’s ARP table using `arp -a` before, during, and after the spoofing process, as summarized in Table 2.

Table 2: ARP cache state on Computer B before, during, and after the spoofing attack launched from Computer A

| Stage  | ARP Cache State on Computer B                                                                                        |
|--------|----------------------------------------------------------------------------------------------------------------------|
| Before | The gateway IP resolves to the genuine router MAC; Computer A’s IP and the gateway IP map to distinct MAC addresses. |
| During | The gateway IP resolves to Computer A’s MAC; traffic from B addressed to the gateway is delivered to A instead.      |
| After  | The gateway IP reverts to the genuine router MAC once arpspoof is stopped on Computer A.                             |

The poisoned entry confirms that the switch segment accepts unsolicited ARP replies without verification, and that Computer B’s outbound traffic toward the gateway – and therefore toward the campus backend – would be delivered to the attacker for the duration of the attack.

### 3.4 Dictionary Attack

**3.4.1 Attack Rationale.** This attack targets the HTTP web management login interface exposed by the BF-430 (Component ④) on port 80. Since this interface provides administrative access to the device, weak or guessable credentials could allow an attacker on the same reachable network segment to gain control of the BF-430 without exploiting a software vulnerability. Therefore, we tested whether dictionary-based credential guessing was feasible.

**3.4.2 Experimental Setup.** We connected the attacking machine to the same reachable network segment as the BF-430 device and tested two password dictionary sources with the same automated HTTP brute-force script.

- (1) **Customized wordlist via pydictor.** A context-aware password wordlist was generated using `pydictor` [10], seeded with terms relevant to the target environment, including `ntu`, `33663366` (NTU’s main switchboard number), `acu`, `access`, `control`, and `admin`. These terms were expanded using common password-mutation rules, including leetspeak substitutions, year suffixes, and symbol appending at rule level 3. This experiment was paired with a broader list of commonly used usernames.
- (2) **General-purpose wordlist.** As a second test, we used a larger general-purpose password wordlist [3] commonly available online, containing approximately 235,000 entries.

This experiment was paired with seven common administrative usernames: admin, root, user, ntu\_access, ntu, ntu\_acu, and ntu\_admin.

First, we connected the attacking machine to a network segment from which the BF-430 device was reachable. For both customized wordlist and general-purpose wordlist, the same automated login-testing script was used, with the username candidates configured according to each experiment. The script iterated over each username/password pair, submitted a login request to the device’s web management login interface, and recorded the corresponding HTTP response status.

**3.4.3 Results.** Neither dictionary-based test identified a valid credential. Both the customized 8,139-entry wordlist and the larger 235,000-entry general-purpose wordlist failed to produce a successful login. Across all tested username/password combinations, the BF-430 web interface returned HTTP 401 (Unauthorized), indicating that none of the tested credentials were accepted.

During the tests, however, we observed that the BF-430’s web interface implements a sliding-window rate-limiting mechanism. Requests are permitted up to a threshold of 250 requests within any rolling 60-second window. Once this threshold is exceeded, the device does not return an HTTP 429 (Too Many Requests) response. Instead, it blocks requests at a lower level, producing behaviors such as Connection refused or abrupt TCP connection termination without any HTTP response. Since the mechanism does not impose a fixed lockout duration or permanent account lock, normal request handling resumes automatically once the request count in the trailing 60-second window falls below the threshold. This interface remains a practically feasible attack surface: given sufficient time and a sufficiently accurate password dictionary, credential guessing remains a realistic threat despite the presence of rate limiting.

## 4 Related Work

### 4.1 RFID and Smart-Card Credential Security

Prior work on contactless credential security has largely focused on breaking the cryptographic protections of the MIFARE Classic family. Garcia et al. [6] and Nohl et al. [12] reverse-engineered the proprietary Crypto1 cipher, showing that an attacker who recovers a card’s sector keys can read, clone, or modify its memory contents – motivating a long-running migration toward ISO 14443-4 smart cards. The deployment studied here never reaches the point where Crypto1 matters: because the controller authenticates solely on the 4-byte UID and never activates the application layer, the cloning attack in Section 2 requires none of this cryptanalysis – an even weaker baseline than the systems these studies targeted.

### 4.2 Access Control and IoT/OT Device Security

Jones et al. [9] provide a general taxonomy of attacks against access-control readers, and Ciancaglini et al. [2] document empirical attacks against edge-based access-control devices, including credential replay and controller manipulation. Chung [1] shows that the reader-to-controller Wiegand link transmits the card number unencrypted, allowing it to be sniffed or replayed. These works establish that individual pipeline components – reader, Wiegand bus,

controller – are each independently vulnerable. Our study extends this line by tracing an attack path through an additional component, the serial-to-IP converter, and chaining a physical-layer weakness (UID cloning) with a network-layer weakness (ARP spoofing of this converter) into a single end-to-end scenario.

### 4.3 ARP Spoofing and Man-in-the-Middle Attacks

ARP cache poisoning has been documented since at least Whalen et al. [15], and countermeasures followed quickly: Ramachandran and Nandi [13] propose active probing to detect spoofed ARP replies, and modern switches implement Dynamic ARP Inspection (DAI), validating ARP packets against trusted IP-to-MAC bindings [4]. Despite being a two-decade-old, well-defended attack, our results (Section 3.3) show it remains fully viable on the switch segment serving the BF-430, since none of these countermeasures – DAI, port security, or static ARP bindings – appear configured. This reflects a recurring theme in OT/IoT security: defenses mature in general-purpose IT networks are often absent from segments serving embedded physical-security devices.

### 4.4 Credential Brute-Forcing

Florêncio and Herley [5] found in a large-scale study that weak, short, and reused passwords are pervasive, and that systems without rate-limiting or lockout are readily susceptible to automated guessing. This directly informs the feasibility of the dictionary attack against the BF-430’s web interface (Section 3.4): the absence of any brute-force countermeasure, combined with predictable vendor-default and institution-themed credentials, places it squarely within the exploitable regime this prior work characterizes.

### 4.5 Summary

Prior work largely treats the credential, reader/controller, and network layers as separate problems, each with its own attacks and defenses. This paper’s contribution is to show that, in a real deployment, these layers are not independent: an unauthenticated UID combined with an unprotected ARP cache on the network-facing converter yields a compound attack – unauthorized entry whose audit trail can be erased in transit – that no single layer’s defenses would prevent.

## 5 Conclusion and Future Work

This work shows that the security risks in the NTU access control system do not come from a single isolated vulnerability, but from a chain of legacy design choices across the physical credential layer, the network layer, and the device management layer. Therefore, the main lesson is that access control systems should be secured as an end-to-end cyber-physical pipeline rather than as separate door devices. Based on this observation, we summarize practical remediation strategies, discuss the broader impact of our findings, and outline future directions for a more complete security analysis.

### 5.1 Layered Remediation Strategy

Instead of treating each attack independently, we propose a layered remediation strategy based on the access control pipeline. Since

multiple attacks originate from the same architectural weaknesses, one defensive measure can often mitigate several risks at once. The proposed defenses are divided into immediate mitigations that can be deployed quickly, and long-term remediations that address the root causes.

**RFID Card.** At the card and reader layer, the main weakness is that the current system appears to rely on the plaintext UID of MIFARE Classic cards as the primary credential. This makes the system vulnerable to UID cloning, because an attacker who copies the UID to a magic card may be able to impersonate the original card.

As an immediate mitigation, the backend could introduce access-log auditing and anomaly detection. For example, the system can flag impossible travel patterns, repeated use of the same UID at distant doors within a short time, or unusually frequent access attempts from the same card. This does not fully prevent UID cloning, but it allows administrators to detect suspicious cloned-card behavior quickly without replacing all cards immediately.

In the long term, the school should adopt new cards and readers that support stronger credential protocols, such as ISO 14443-4. This migration path is realistic because several educational institutions have already transitioned from legacy ISO 14443-3-based systems to ISO 14443-4 smart-card deployments. A staged deployment is more practical than replacing all readers at once: high-risk areas such as server rooms and laboratories can be upgraded first, while lower-risk doors continue to support legacy cards during the transition period. New staff, students, and replacement cards can then be issued using the stronger credential technology, allowing the legacy UID-based mode to be gradually phased out without disrupting daily operations.

**Network Layer.** At the network layer, ARP spoofing and plaintext interception are possible mainly because the access control devices are reachable from a shared or insufficiently isolated subnet. In our experiment, we only performed single-direction ARP poisoning on a controlled victim machine rather than the production BF-430. However, because the victim machine was placed in the same subnet and switch environment as the BF-430, the result suggests that the BF-430 would likely be vulnerable under the same network conditions. If the BF-430 itself were targeted, an attacker could potentially intercept upstream traffic to the backend over TCP port 4660 and HTTP port 80, or selectively drop audit messages generated after a cloned-card entry. This is an architectural issue, so one mitigation can reduce the impact of several attacks at once, including ARP spoofing, Telnet exposure, and web login brute force.

As an immediate mitigation, the school should restrict who can communicate with the access control devices. Firewall or switch ACLs should allow access only from explicit administrator IP addresses and backend servers. In particular, TCP port 23 for Telnet and the web management interface should not be reachable from general campus networks. The switch segment should also enable standard Layer-2 protections such as Dynamic ARP Inspection [4], port security, or static ARP bindings where feasible.

As a long-term remediation, all physical security infrastructure should be moved into a dedicated IoT/Facility VLAN that is strictly

separated from normal campus networks. This prevents unauthorized devices from easily joining the access-control subnet and reduces the feasibility of ARP-based man-in-the-middle attacks.

**Device Management.** At the BF-430 management layer, the major risks are exposed legacy services, including Telnet and the web management interface. The deployed BF-430 converter was found to be running firmware dated 2006. This is a significant security concern because legacy firmware may lack modern security mechanisms, and may expose outdated management services such as Telnet. Therefore, the school should inventory all BF-430 devices, verify their firmware versions, and upgrade them to vendor-supported secure firmware where available. If a clearly patched firmware version is unavailable, the devices should be replaced with modern serial-to-IP converters that support secure management protocols such as SSH and HTTPS.

## 5.2 Impact

The broader impact of this work is to show that legacy physical access control systems should be evaluated as cyber-physical infrastructure, not merely as door hardware. Many campus and enterprise deployments keep using long-lived embedded devices and UID-based cards because they are cheap, convenient, and difficult to replace without disrupting daily operations. However, relying on an unencrypted and unauthenticated UID as the access credential is dangerous, since the UID was designed as an identifier rather than a secure proof of identity. Our results therefore highlight the need for practical, incremental defenses.

## 5.3 Future Work

Future work could extend the study to other layers of the access control pipeline. In particular, we would further investigate whether the door access controller's local database or permission table can be manipulated through malformed update commands. We would also examine the reader-to-controller communication path in our campus deployment to verify whether it provides confidentiality and replay protection.

For the network-layer attack, future work could evaluate full bidirectional MITM feasibility in an explicitly authorized test environment. Our current experiment only forged the gateway's identity toward a controlled victim machine; a full MITM would additionally require redirecting return traffic from the gateway side, which was outside our authorized testing scope.

## Ethical Considerations

All experiments in this work were conducted under prior authorization from NTU's and CSIE's relevant units and within the approved research scope. The goal of the study was to evaluate security risks and propose defensive improvements, not to disrupt campus operations or obtain unauthorized access. During testing, we followed a non-destructive principle: no hardware was damaged, no production service was intentionally interrupted, and no personal data of students or staff was collected, stored, or disclosed. Any potentially sensitive findings were treated confidentially and are intended to be reported to the responsible administrators before public release.

## References

- [1] B. Chung. 2017. Wiegand Protocol Access: A Decade of Decryption. <https://www.cs.tufts.edu/comp/116/archive/fall2017/bchung.pdf>.
- [2] Vincenzo Ciancaglini, Joey Costoya, Philippe Lin, and Roel Reyes. 2020. *Identified and Authorized: Sneaking Past Edge-Based Access Control Devices*. Technical Report. Trend Micro.
- [3] cihanmehmet. 2020. Password Wordlist(235k). GitHub Gist. Retrieved June 16, 2026 from <https://gist.github.com/cihanmehmet/68abd1a11b3477ebd30eea7ef23183b5>
- [4] Cisco Systems. 2020. Configuring Dynamic ARP Inspection. [https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst9200/software/release/17-2/configuration\\_guide/sec/b\\_172\\_sec\\_9200\\_cg/configuring\\_dynamic\\_arp\\_inspection.html](https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst9200/software/release/17-2/configuration_guide/sec/b_172_sec_9200_cg/configuring_dynamic_arp_inspection.html). Accessed: 2026-06-15.
- [5] Dinei Florêncio and Cormac Herley. 2007. A Large-Scale Study of Web Password Habits. In *Proceedings of the 16th International World Wide Web Conference (WWW)*. 657–666. doi:10.1145/1242572.1242661
- [6] Flavio D. Garcia, Gerhard de Koning Gans, Ruben Muijers, Peter van Rossum, Roel Verdult, Ronny Wichers Schreur, and Bart Jacobs. 2008. Dismantling MI-FARE Classic. In *13th European Symposium on Research in Computer Security (ESORICS)*. Springer, 97–114.
- [7] HITCON ZeroDay. 2025. ZD-2025-01584: CHIYU BF-430 Telnet Authentication Bypass. <https://zeroday.hitcon.org/vulnerability/ZD-2025-01584>. Accessed: 2026-05-21.
- [8] ISO/IEC. 2016. *Identification Cards — Contactless Integrated Circuit Cards — Proximity Cards*. Standard. International Organization for Standardization. <https://iso.org>
- [9] Peter Jones, Lowri Williams, and Eirini Anthi. 2026. The Anatomy of an Access Control Reader: A Cybersecurity Perspective. *Journal of Cybersecurity* (2026).
- [10] LandGrey. 2026. pydictor: A Powerful and Useful Hacker Dictionary Builder for a Brute-Force Attack. Online documentation. Retrieved June 16, 2026 from [https://landgrey.github.io/pydictor/README\\_CN.html](https://landgrey.github.io/pydictor/README_CN.html)
- [11] National Vulnerability Database. 2021. CVE-2021-31251: CHIYU BF-430 Authentication Bypass (CVSS 9.8). <https://nvd.nist.gov/vuln/detail/CVE-2021-31251>. Accessed: 2026-05-21.
- [12] Karsten Nohl, David Evans, Starbug, and Henryk Plötz. 2008. Reverse-Engineering a Cryptographic RFID Tag. In *17th USENIX Security Symposium*. 185–193. <https://www.usenix.org/conference/17th-usenix-security-symposium/reverse-engineering-cryptographic-rfid-tag>
- [13] Vivek Ramachandran and Sukumar Nandi. 2005. Detecting ARP Spoofing: An Active Technique. In *Information Systems Security (ICISS 2005) (Lecture Notes in Computer Science, Vol. 3803)*. Springer, 239–250. doi:10.1007/11593980\_18
- [14] wakdev. 2026. NFC Tools. Android application, Google Play. Retrieved June 16, 2026 from <https://play.google.com/store/apps/details?id=com.wakdev.wdnfc>
- [15] Sean Whalen, S. Engle, and Dominic Romeo. 2001. An Introduction to ARP Spoofing. SANS Institute InfoSec Reading Room.